

How to Find Your First Bug Bounty In Vulnerability: Step-by-Step Beginner Guide (2026)

Hello, hacker friends and brothers! Welcome to this guide on finding your first bug bounty vulnerability.If you’re beginning your journey…

SAYEM-EH

Published June 9, 2026

Free: Yes

Read on Freedium · original

Contents

 1. Select the Suitable Program 0

❯❯ 2. Step One: Basic Reconnaissance 0

 3. Find a Simple Attack Surface 0

⚔ 4. Easy Attack Vectors to Start With (Low-Hanging Fruit)

 5. Common Vulnerabilities Found by Beginners 0

 6. Essential Tools for Beginners 0

7. A Simple Approach to Find Your First Bug 0

 8. The Right Mindset 0

 9. Practical Checklist for Your First Bug 0

 10. Final Thoughts — Learn and Apply 0

Hello, hacker friends and brothers! Welcome to this guide on finding **your first bug bounty vulnerability**.If you're beginning your journey in bug bounty hunting and wondering where to start, this article will walk you through the fundamental process used by many successful researchers.

Without unnecessary complexity, let's dive directly into the practical steps.

1. Select the Suitable Program

This is where newbies usually mess up. They begin hunting bugs from large organizations such as NASA, Google, and Facebook.

✔ Instead, On the other hand, try finding the one that:

- Has a large scope (e.g., **subdomains, APIs, web applications, mobile applications**).
- Accept **beginner hackers** (via VDP — Vulnerability Disclosure Programs — or open bug bounty programs).
- Provide systems that are easy to test, like blogs, public APIs or simple web portals.

Recommendations:

- Platforms like **HackerOne** (Public Programs)**, Bugcrowd** (Public Programs)**, YesWeHack, Intigriti, Synack (**for experienced users).
- Begin with those that offer smaller amounts or are just for **VDPs**. **They tend to be less populated and explored.**

❯❯ 2. Step One: Basic Reconnaissance

This is where the fun begins — the hacking part! **{Bug Hunters understanding why smart reconnaissance yields 80% of testing success.}**

Focus on:

- **Discovering subdomains.**
- **Finding hidden directories and files.**
- **Identifying technologies used by the target.**

Basic Tools for Recon:

- **Subdomain enumeration:** subfinder, amass, assetfinder
- **Directory brute-force:** feroxbuster, ffuf, Dirbuster
- **Tech fingerprinting:** whatweb, nmap,or browser extensions like Buildwith,Wappalyzer.

🔍 3. Find a Simple Attack Surface

Look for areas where user interaction happens — these are potential entry points for vulnerabilities.

Check for:

- **Login, signup, search, or contact pages.**
- **Input forms.**
- **URLs with parameters (e.g., ?id=1, ?search=query).**
- **APIs that accept user input (JSON requests).**
- **File upload functions.**

Tools: GF | Katana

⚔ 4. Easy Attack Vectors to Start With (Low-Hanging Fruit)

🔍 Where to Look

🔍 What to Test

Login pages

Brute-force, CSRF, username enumeration.

Search forms

Reflected XSS (<svg/onload=alert(1)>).

URLs with parameters

IDOR (/user?id=123 → test with /user?id=124).

File uploads

Upload malicious files (.php, .js).

Exposed directories

Check /admin, /backup/, /test/.

Misconfigurations

Missing security headers (CSP, HSTS, etc.).

5. Common Vulnerabilities Found by Beginners

These are realistic and commonly found bugs that beginners can target:

- **IDOR (Insecure Direct Object Reference)** → Test whether modifying object identifiers in URLs, API endpoints, or request parameters allows unauthorized access to other users' accounts, records, or resources.
- **XSS (Cross-site Scripting) — Reflected** → Identify user-controlled inputs that are reflected in server responses and assess whether they can be leveraged to execute malicious client-side scripts.
- **CSRF (Cross-site Request Forgery)** → Evaluate whether sensitive actions, such as updating account information or changing passwords, can be triggered through forged requests without adequate CSRF protections.
- **Misconfigurations** → Open directories (/backup.zip), exposed .git folders, .env files, open FTP/SSH services.Identify exposed files, open directories, misconfigured services, and leaked sensitive data.
- **Subdomain Takeover (Occasionally)** → Investigate subdomains that reference decommissioned or unclaimed third-party services, which could potentially allow an attacker to claim and control the affected subdomain.

 I plan to write a dedicated article on each of these vulnerabilities soon.

6. Essential Tools for Beginners

Category

Tools

Subdomain discovery

subfinder, amass

Directory brute-force

ffuf, feroxbuster, dirbuster

IP reconnaissance

nmap

Fingerprinting tech stack

whatweb, Buildwith ,wappalyzer

Parameter fuzzing

ffuf, paramspider, GF

General exploitation

Burp Suite (must-have)

7. A Simple Approach to Find Your First Bug

1 Choose an **active subdomain**. 2 Run **directory fuzzing** — check for /admin, /login, /search, etc. 3 Test any **input field** or **parameter** that reflects data back. 4 Look for **IDORs** by changing numbers in parameters (?id=1 → ?id=2). 5 Try basic **XSS payloads** like:

"><svg/onload=alert(1)>

6 Check for **missing security headers** using https://securityheaders.com (https://securityheaders.com/). 7 Attempt **brute-force login** on admin panels if there's **no rate limiting.**

8. The Right Mindset

- Stick to the fundamentals. Many successful hunters discover their first valid findings by mastering the basics rather than chasing complex vulnerabilities.
- If a target doesn't yield results, don't get discouraged — move on and keep exploring. Every experienced hunter has faced countless dead ends before finding success.
- Train yourself to spot unusual or unexpected behavior in web applications. Small anomalies often reveal valuable security weaknesses.
- Document everything throughout your journey. Even unsuccessful tests provide insights, sharpen your skills, and contribute to your growth as a security researcher. It's a habit that continues to pay off over time.

9. Practical Checklist for Your First Bug

- Subdomain discovered.
- Directory fuzzing completed.
- Input fields and parameters identified.
- Basic XSS payloads tested.
- IDOR attempts performed.
- Security headers checked.
- Looked for sensitive files (/backup.zip, /test/.env).
- If nothing is found, **switch targets and repeat.**

10. Final Thoughts — Learn and Apply

If you stay consistent with this process, your first vulnerability may come sooner than you expect.

Bug hunting is all about patience, persistence, and curiosity — keep learning and exploring, and the results will follow.

That's it for today! If you enjoyed this content, leave a clap, comment, and follow me for more guides.

Happy Hunting! ☠

GoodBye